Politique d’authentification - Lidl Collect

INTRODUCTION : UNE SÉCURITÉ PENSÉE POUR TOUS

Chez Lidl, la confiance de nos utilisateurs est essentielle. Avec l’application **Lidl Collect**, nous avons conçu un système d’authentification qui protège vos données tout en restant simple à utiliser au quotidien.

Que vous soyez client, préparateur de commandes ou administrateur, chaque accès à la plateforme est sécurisé selon son niveau de sensibilité. Notre objectif est clair : garantir que chacun accède uniquement à ce qui lui est autorisé, tout en assurant une expérience fluide.

Pour construire cette architecture, nous nous appuyons sur les recommandations d’organismes reconnus comme ANSSI, CNIL et OWASP.

COMPRENDRE COMMENT VOUS VOUS CONNECTEZ

Lorsque vous vous connectez à Lidl Collect, plusieurs éléments permettent de vérifier votre identité.

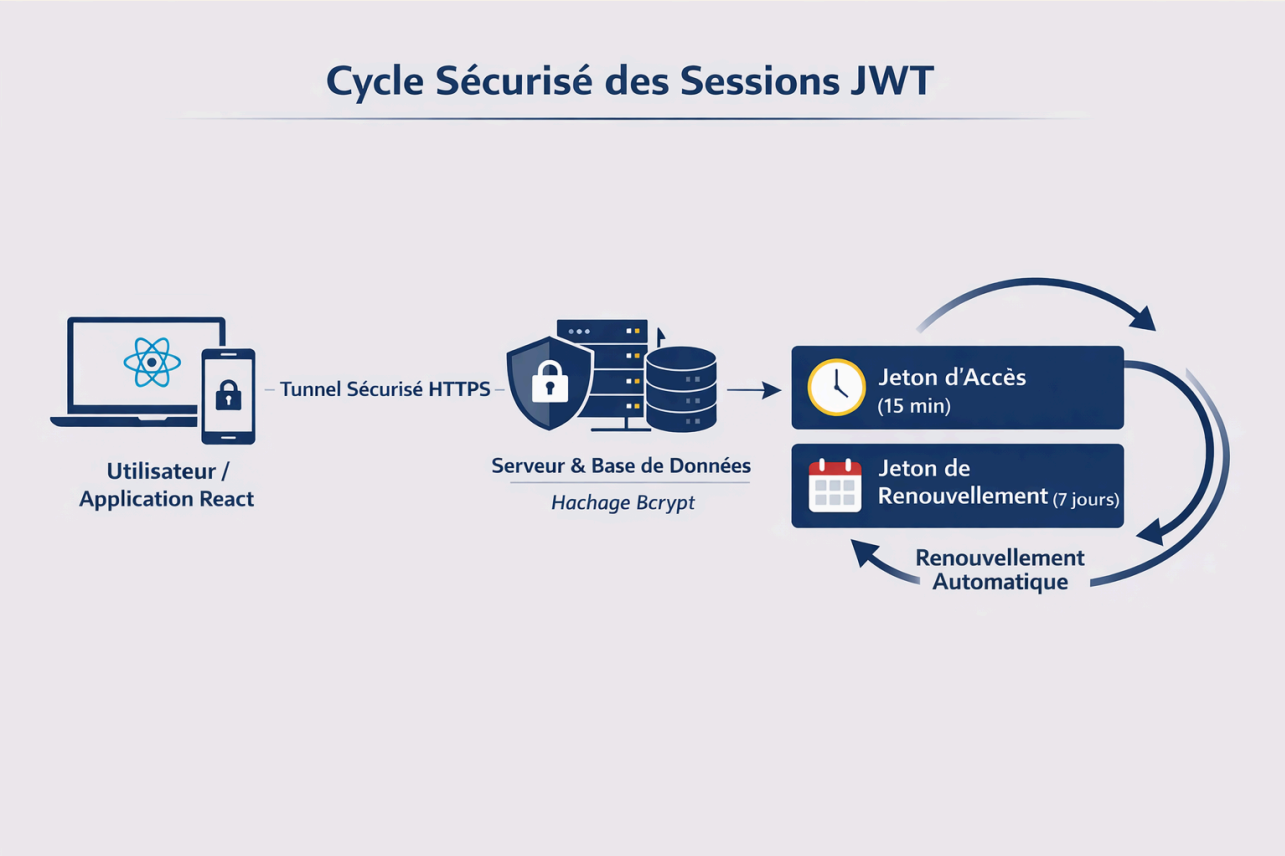
Le premier est votre mot de passe, que vous seul connaissez. C’est ce qu’on appelle un facteur de connaissance. Dans certains cas, nous demandons également un second élément, comme un code généré sur votre téléphone. Cela correspond à un facteur de possession.

Le fait de combiner ces éléments s’appelle l’authentification forte, ou MFA. Elle est recommandée par l’ANSSI pour protéger les accès sensibles, notamment pour les comptes internes.

POURQUOI NOUS UTILISONS LES TOKENS (JWT)

Pour vous permettre de naviguer facilement dans l'application sans avoir à vous reconnecter en permanence, Lidl Collect utilise une technologie appelée **JWT (JSON Web Token)**.

Concrètement, après votre connexion, nous vous attribuons un jeton numérique sécurisé. Ce jeton fonctionne comme un badge temporaire qui prouve votre identité à chaque action.



Ce choix repose sur plusieurs raisons.

D'abord, il permet une navigation rapide et fluide, notamment sur mobile. Ensuite, il évite de stocker des sessions côté serveur, ce qui améliore les performances et la stabilité de la plateforme. Enfin, il permet d'intégrer directement votre rôle dans le système, ce qui facilite la gestion des droits.

Cette approche est aujourd'hui largement utilisée et recommandée dans les architectures modernes, notamment par les bonnes pratiques de l'OWASP.

UNE SÉCURITÉ RENFORCÉE GRÂCE À LA GESTION DES SESSIONS

Le système Lidl Collect repose sur deux types de jetons complémentaires qui permettent de sécuriser votre session tout en garantissant une navigation fluide.

Lors de votre connexion, un premier jeton appelé **Access Token** vous est attribué. Ce jeton est utilisé pour toutes vos actions dans l'application. Afin de limiter les risques en cas d'interception, sa durée de validité est volontairement courte. Chez Lidl Collect, elle est fixée à **15 minutes pour les clients et les opérateurs**, et **10 minutes pour les comptes administrateurs**, qui nécessitent un niveau de sécurité encore plus élevé.

Une fois ce délai dépassé, le jeton n'est plus utilisable. Cela permet de réduire fortement la fenêtre d'exploitation en cas de tentative d'accès frauduleux.

Pour éviter de vous demander de vous reconnecter en permanence, un second jeton appelé **Refresh Token** est utilisé. Celui-ci permet de générer automatiquement un nouveau Access Token lorsque le précédent expire.

La durée de ce second jeton est plus longue, mais elle est adaptée selon le niveau de sensibilité du compte. Pour un client, la session peut être maintenue jusqu'à **7 jours**, afin de garantir une expérience utilisateur confortable. En revanche, pour les utilisateurs internes, cette durée est réduite à **8 heures pour les opérateurs et managers**, et à **4 heures pour les administrateurs**, conformément aux recommandations de sécurité renforcée pour les accès sensibles.

Ce mécanisme permet de trouver un équilibre entre simplicité d'utilisation et niveau de protection élevé, en accord avec les bonnes pratiques recommandées notamment par l'OWASP et l'ANSSI.

COMMENT VOS MOTS DE PASSE SONT PROTÉGÉS

La sécurité de votre compte commence dès la création de votre mot de passe.

Chez Lidl Collect, aucun mot de passe n'est stocké tel quel. Nous utilisons une technique appelée **hachage**, qui transforme votre mot de passe en une version illisible. Cette transformation est irréversible, ce qui signifie que même nous ne pouvons pas retrouver votre mot de passe d'origine.

Nous utilisons l'algorithme **Bcrypt**, recommandé par la CNIL pour le stockage des mots de passe. Son avantage principal est qu'il ralentit volontairement les calculs, ce qui rend les attaques informatiques extrêmement difficiles.

Il existe également un algorithme plus récent appelé Argon2, recommandé par l'ANSSI. Celui-ci est encore plus avancé techniquement, notamment face aux attaques utilisant des cartes graphiques. Cependant, Bcrypt reste aujourd'hui une solution fiable, éprouvée et largement utilisée dans les systèmes en production, ce qui justifie notre choix dans le cadre de Lidl Collect.

En complément, nous ajoutons une donnée aléatoire unique appelée "sel" à chaque mot de passe. Cela empêche deux mots de passe identiques d'avoir le même résultat, renforçant encore la sécurité.

DES ACCÈS ADAPTÉS À CHAQUE UTILISATEUR

Tous les utilisateurs n’ont pas les mêmes besoins, ni les mêmes niveaux de risque. C’est pourquoi Lidl Collect applique une gestion des accès par rôle.

Un client accède uniquement à ses propres commandes et informations. Un opérateur peut consulter les commandes pour les préparer, mais n’a pas accès aux données sensibles des clients. Un manager supervise les opérations, tandis qu’un administrateur dispose d’un accès complet.

Plus le niveau de responsabilité est élevé, plus les mesures de sécurité sont renforcées. Par exemple, les accès internes nécessitent une authentification forte, et certaines connexions sont limitées à des environnements sécurisés.

Cette approche suit le principe du moindre privilège recommandé par l’ANSSI et les bonnes pratiques de l’OWASP.

UNE PROTECTION CONTRE LES PRINCIPALES MENACES

Le système intègre plusieurs mécanismes pour se protéger contre les attaques courantes.

En cas de tentatives répétées de connexion, le compte est temporairement bloqué afin d'empêcher les attaques automatisées. Cette mesure est recommandée par l'OWASP.

Les tentatives de fraude, comme le phishing, sont limitées grâce à l'utilisation de la double authentification. Même si un mot de passe est compromis, l'accès reste protégé.

Enfin, les sessions sont sécurisées grâce à des durées limitées et des mécanismes de renouvellement. Cela réduit fortement les risques liés au vol de session.

VOTRE RÔLE DANS LA SÉCURITÉ

La sécurité est aussi une responsabilité partagée.

Nous vous recommandons d’utiliser un mot de passe unique pour votre compte Lidl Collect et de ne jamais le partager. Si vous recevez une demande de code de connexion sans en être à l’origine, il est important de ne pas la valider.

Pour les utilisateurs internes, certaines règles supplémentaires s’appliquent, notamment l’utilisation d’outils sécurisés et le respect des procédures en cas de doute.

CONCLUSION : UNE SÉCURITÉ SIMPLE ET EFFICACE

Avec Lidl Collect, nous avons conçu un système qui allie sécurité et simplicité.

Grâce à l'utilisation de technologies reconnues comme les JWT, le hachage Bcrypt et l'authentification forte, nous protégeons efficacement vos données tout en vous offrant une expérience fluide.

Notre approche repose sur un principe simple : rendre la sécurité invisible pour l'utilisateur légitime, tout en restant robuste face aux menaces.

SOURCES

Recommandations de ANSSI

Recommandations de CNIL

Bonnes pratiques de OWASP

Partie théorique pour le paiement en ligne

stockage des données

Chiffrement : Tu gardes le contrôle total des données sur tes propres serveurs(avantage) incovénient : Si ton serveur est piraté et que la clé de déchiffrement est volée, les pirates lisent toutes les cartes.

Tokenisation : la donnée n'existe pas elle est remplacé par un jeton qui n'a pas de valeur (avantage) incovénient : Dépendance totale envers ton prestataire de paiement (PSP).

Le choix pour Lidl Collect : La Tokenisation.

- **Justification :** C'est le standard recommandé par **IBM** et **Stripe**. En cas de fuite de données, Lidl ne perd rien de sensible.

TRANSPORT ET INTERFACE

Protocole TLS 1.2+ (HTTPS) :

- **Rôle :** Chiffre le "tunnel" entre le client et Lidl.
- **Justification :** Empêche l'interception des données sur le réseau (attaque "Man-in-the-Middle"). Cité par Checkout.com comme la "première ligne de défense".

Intégration par iFrame (Isolation) :

- **Rôle :** Utiliser les champs de saisie du prestataire (ex: Stripe Elements).
- **Justification :** Protège contre le **Formjacking** (virus qui vole ce que l'utilisateur tape). Le numéro de carte ne touche même pas le code de notre site.

Validation (authentification)

. Authentification Forte (3D Secure 2 / 2FA)

- **Techno :** Vérification via mot de passe, dispositif (téléphone) ou biométrie (empreinte/face ID).
- **Avantages :** Confirmation que le paiement a été initié avec le consentement réel de l'acheteur.
- **Justification :** C'est une obligation légale de la **DSP2** pour réduire le risque d'usurpation d'identité.

Machine Learning / Détection de Fraude :

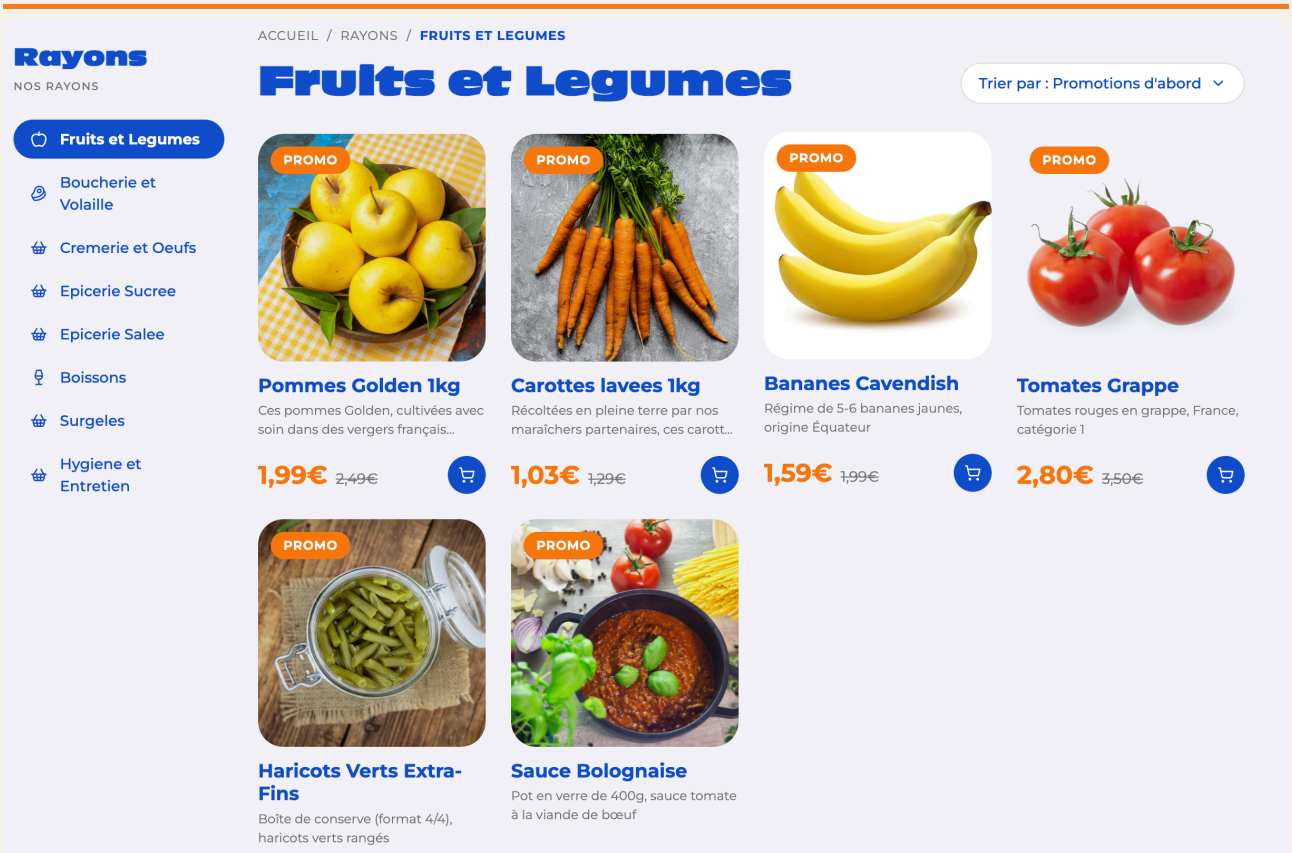
- **Rôle :** Algorithmes qui analysent les comportements suspects (ex: 5 achats en 2 minutes).
- **Justification :** Recommandé par Checkout.com pour bloquer les fraudes avant même qu'elles n'arrivent à l'étape du paiement.

> **CE QUE NOUS "RÉCUPÉRONS" ET "GARDONS"**

Pour prouver au jury que le système est sécurisé :

Nous ne gardons pas : Le numéro de carte, la date d'expiration complète, et surtout **jamais le CVV** (comme rappelé par Checkout.com, il ne doit pas être stocké).

Nous récupérons : Un **Token de paiement** (pour les futurs achats ou remboursements).

- Le statut de la vérification **CVV** (réponse de la banque confirmant que le code saisi était correct).
- Le **Fingerprint** de l'appareil (pour l'outil de détection de fraude).
- Les **4 derniers chiffres** (pour l'affichage client uniquement).

Page coder front